
• • • • • • •

Fabiola Calvillo Galván 182455

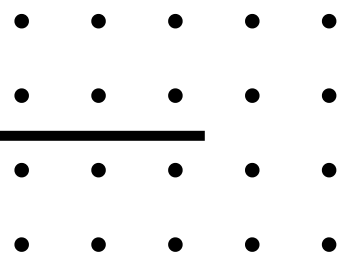
ACT. 08 FILE PATH TRAVERSAL

TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

CNO IV: SEGURIDAD INFORMÁTICA

MTRO. SERVANDO LÓPEZ CONTRERAS

OTOÑO 2026



LABORATORIO:

FILE PATH TRAVERSAL

Introducción

Nombre del laboratorio: File Path Traversal
TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

Nivel del laboratorio: Practitioner

Tipo de explotación: Se trata de una vulneración Path Traversal (también llamada Directory Traversal o Traversal de Directorios) específicamente una variante de lectura arbitraria de archivos.

Objetivo del laboratorio

El objetivo es explotar una vulnerabilidad de path traversal para leer el contenido del archivo `/etc/passwd` del servidor, a pesar de que la aplicación tiene un filtro que bloquea las secuencias de traversal tradicionales (`../`).

Explicación técnica de la vulnerabilidad

La aplicación suele tener una función que carga archivos (por ejemplo, imágenes de productos) a partir de un parámetro controlado por el usuario, algo como:

GET /image?filename=historia-de-un-pais.jpg

Internamente, el servidor concatena ese nombre a una ruta base, por ejemplo:

/var/www/images/ + filename

El filtro de seguridad:

Como defensa, la aplicación intenta detectar y eliminar secuencias de traversal como `../`. Normalmente esto se hace con algo como:

filename = filename.replace("../", "")

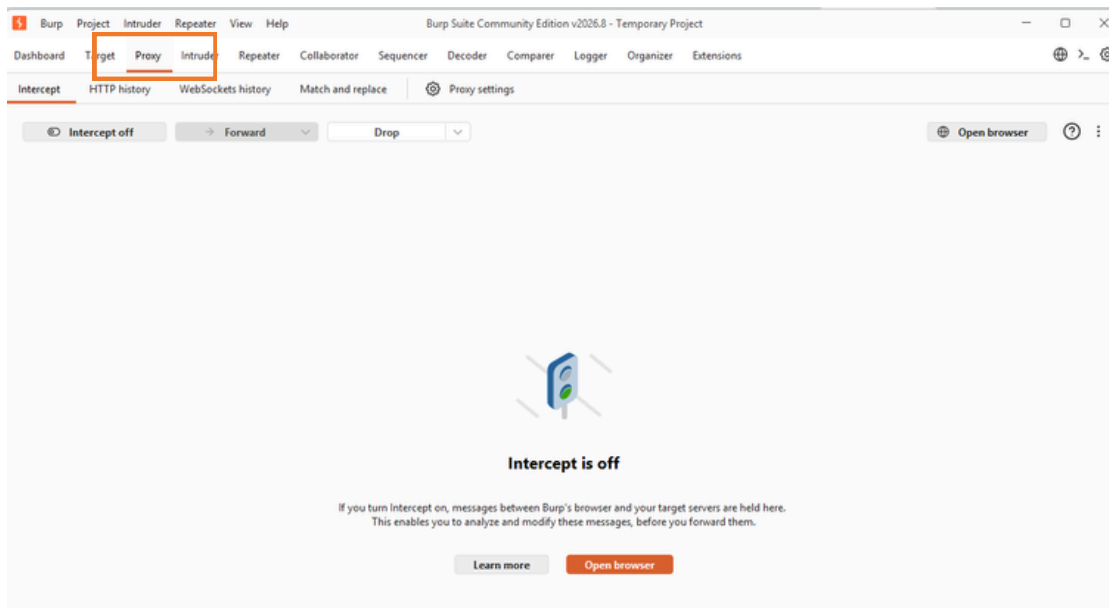
Este tipo de filtro es débil porque solo hace una pasada de sustitución, no es recursivo.

Explotación

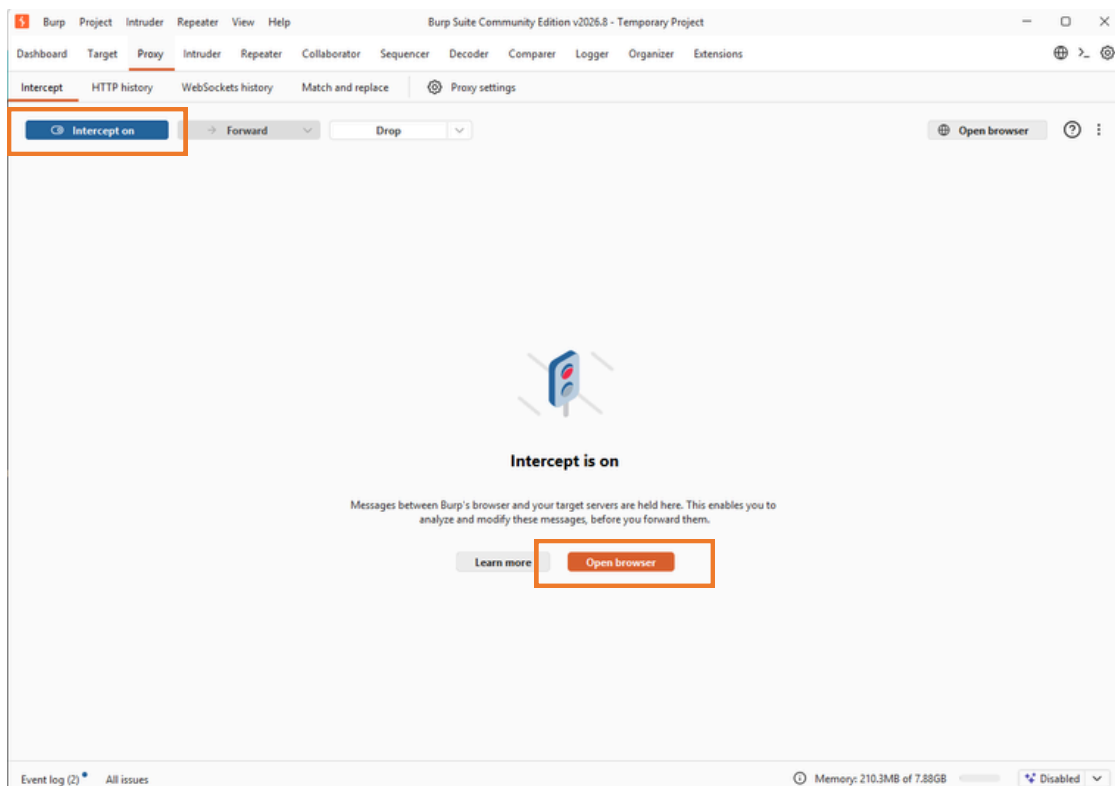
Este laboratorio explota una vulnerabilidad de path traversal en la que la aplicación filtra correctamente las secuencias de traversal relativas (`../`), eliminándolas del parámetro `filename` antes de construir la ruta del archivo a cargar, pero no valida si el valor proporcionado corresponde a una ruta absoluta. Debido a esto, un atacante puede omitir por completo las secuencias `../` y enviar directamente la ruta absoluta del archivo objetivo, por ejemplo `/etc/passwd`, en una petición como **GET /image?filename=/etc/passwd**

Procedimiento paso a paso

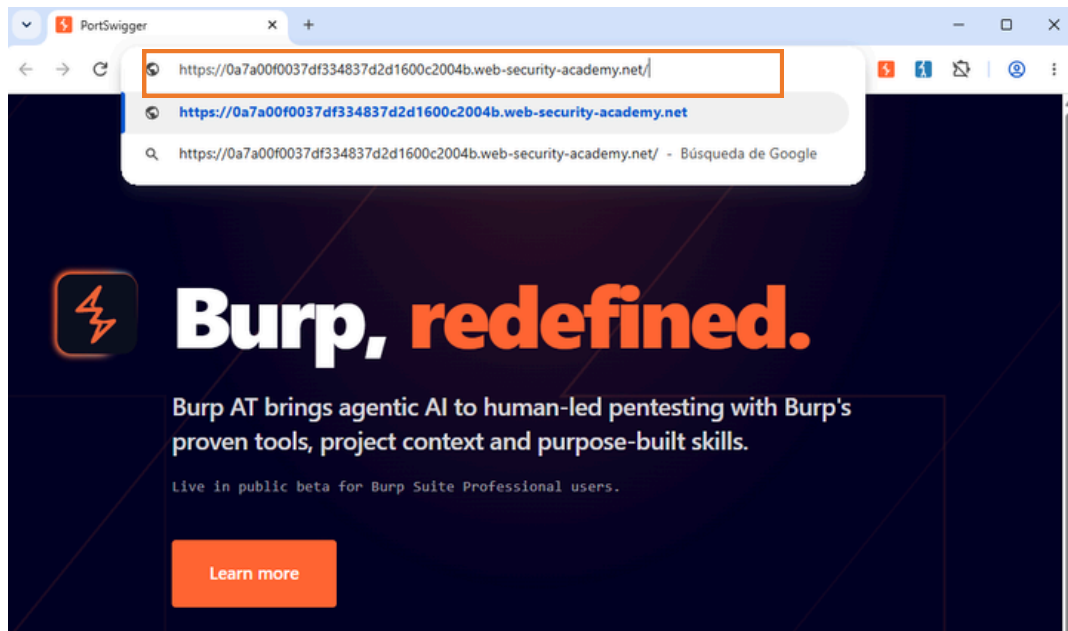
Como primer paso, accedemos a BurpSuite, el sistema que estuvimos usando anteriormente, para después desplazarnos a la pestaña de Proxy.



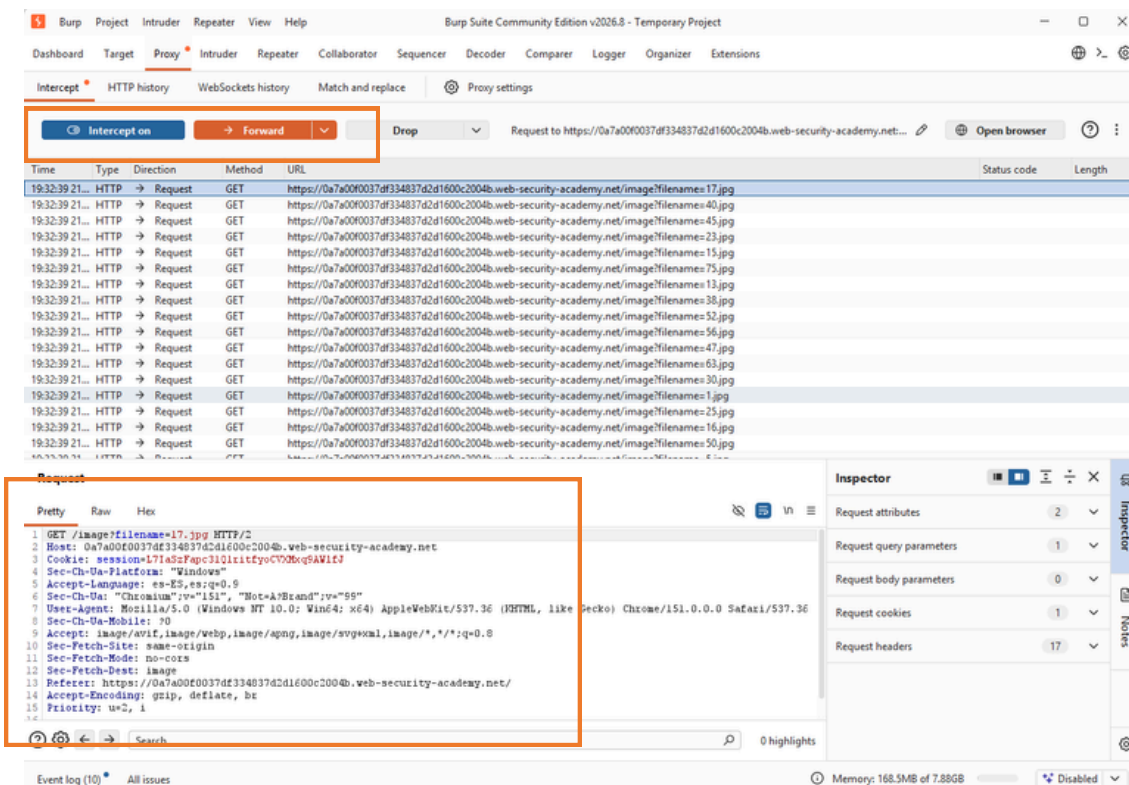
Una vez en la pestaña de proxy, encendemos el interceptador y damos clic en abrir navegador



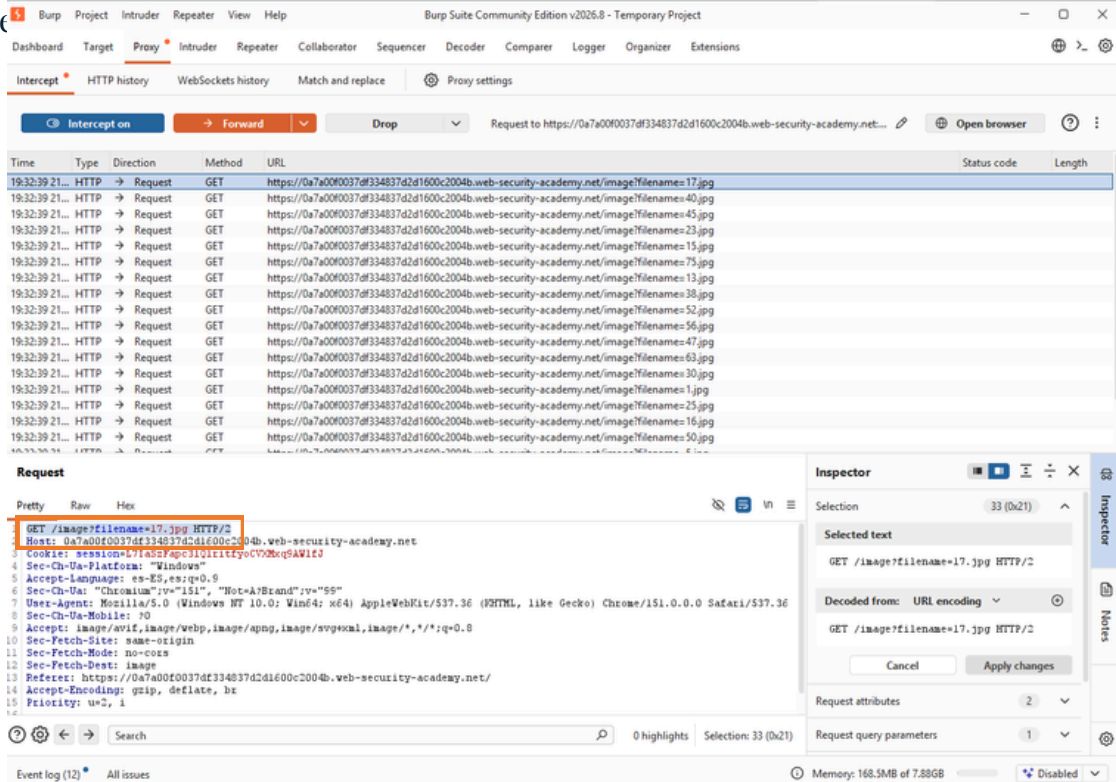
Una vez iniciado el navegador, debemos de pegar el URL de nuestra práctica para poder dar inicio a nuestro laboratorio



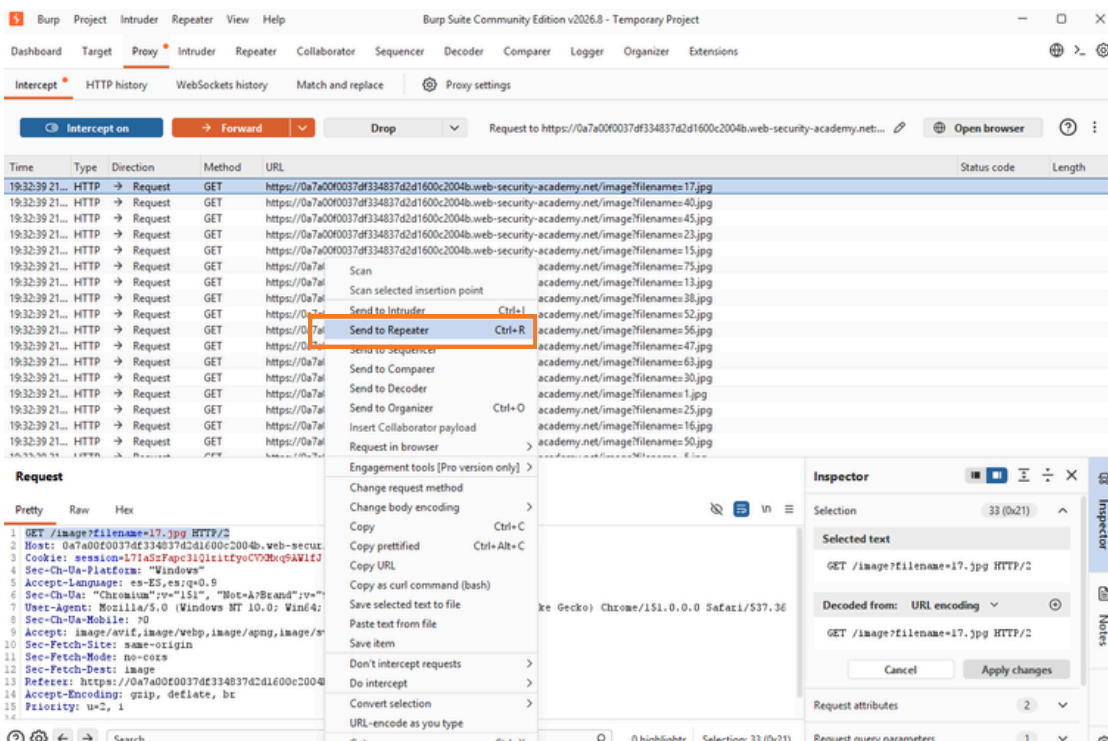
Para poder realizar nuestra práctica, debemos de regresarnos a la ventana de BurpSuite en donde deberemos de dar clic en el botón de **Forward** para que nuestra página pueda cargar y al igual nos carguen las acciones de la página. Debemos de ubicar algún endpoint en nuestra página, que en este caso debe ser algo parecido a: **GET /image?filename=18.jpg HTTP/2**



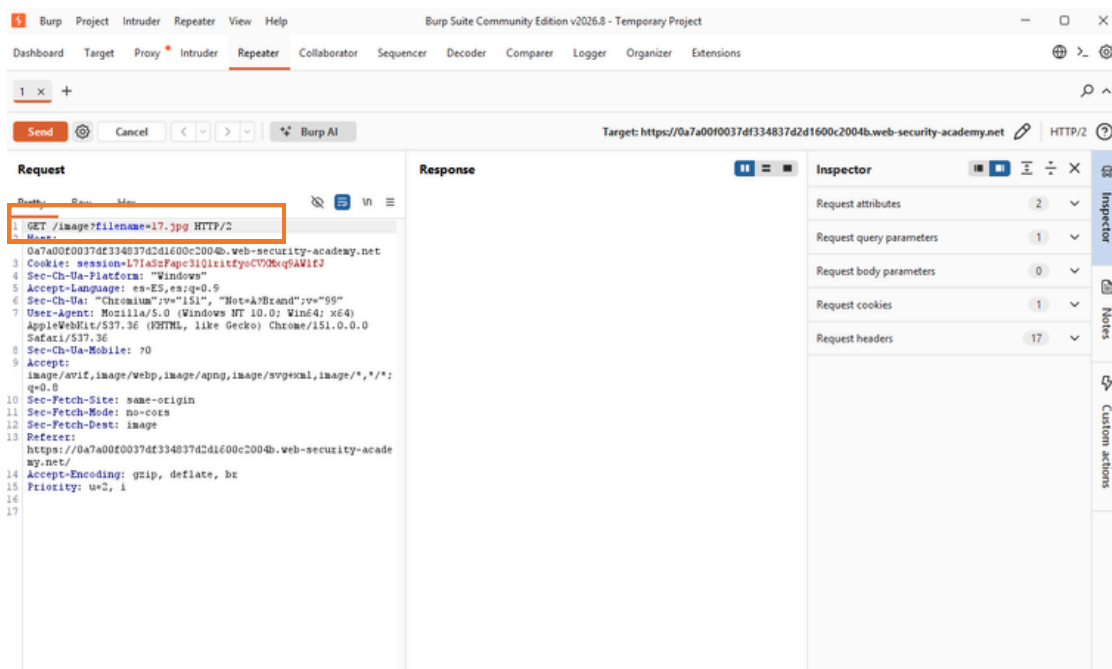
Una vez



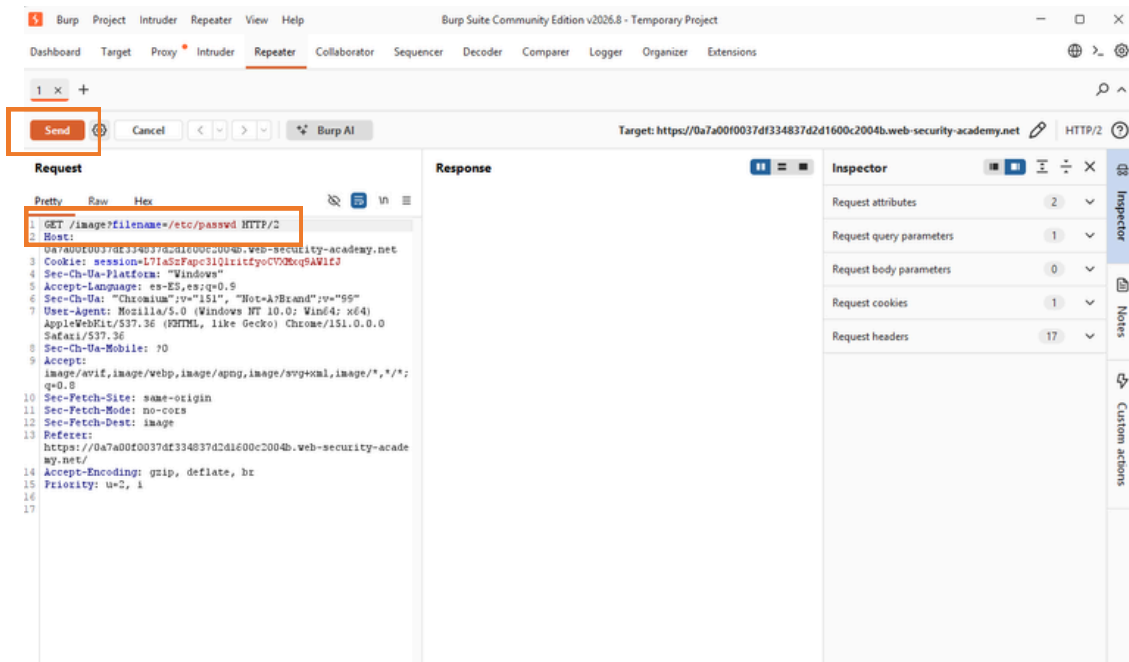
Ya seleccionado debemos de dar clic derecho, en donde se nos mostraran diferentes opciones, de las cuales seleccionaremos la que dice **Send to Repeater**.



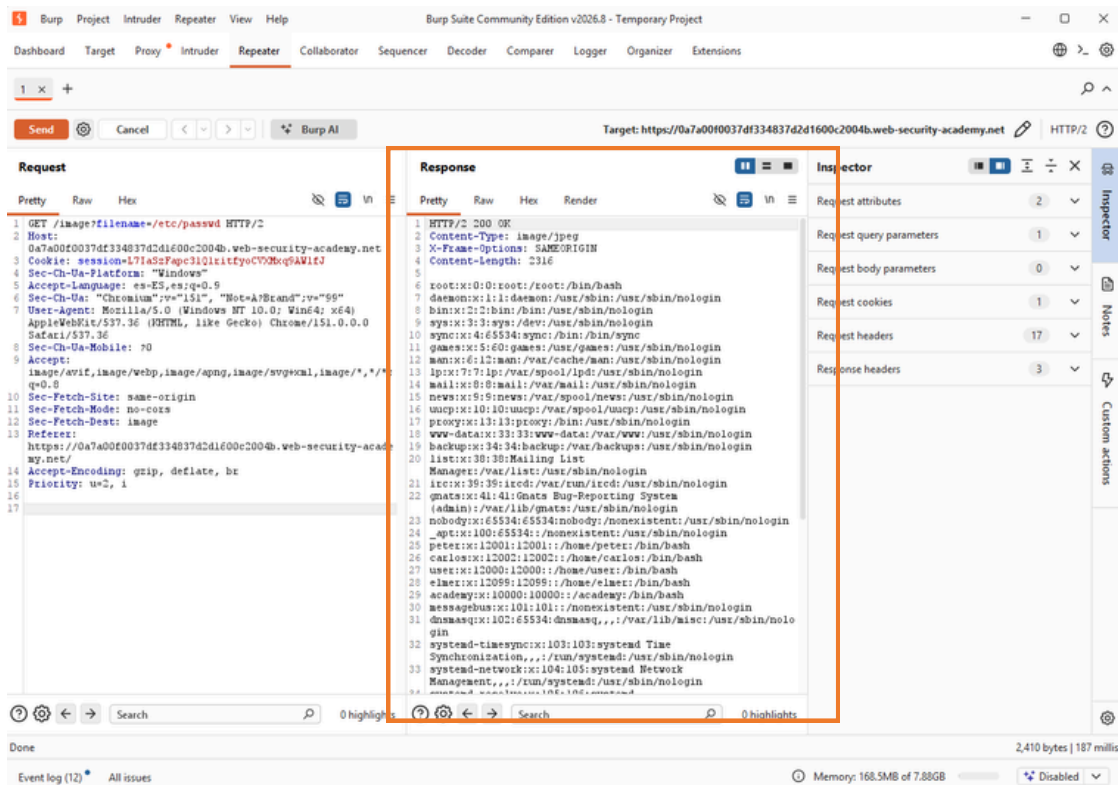
Una vez en la pestaña de **Repeater** debemos de modificar el endpoint, debemos de reemplazar el nombre del **filename**.



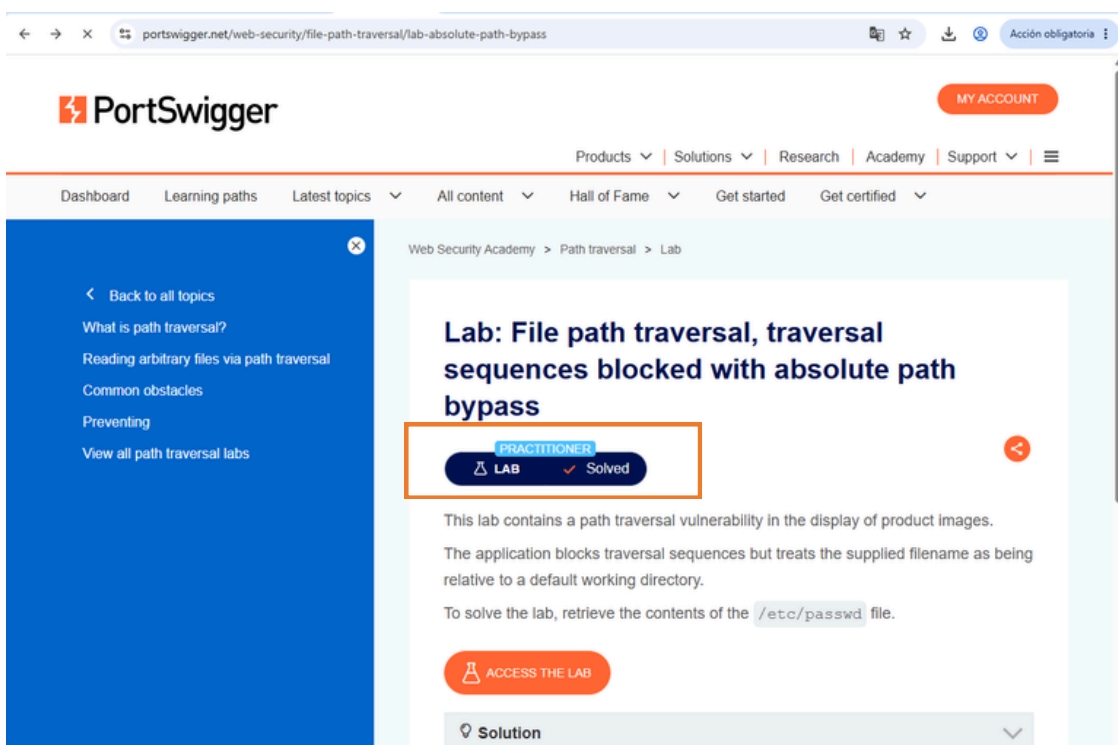
Modificamos el **filename** por lo siguiente: **/etc/passwd** esto para poder movernos de directorio y poder visualizar la información que contiene ese directorio, para eso debemos de dar clic en **Send**, para poder realizar esta acción.



Después de haber mandado la instrucción, en el apartado de **Response** se muestra el contenido del directorio.



Una vez que podemos observar esta información la práctica de este laboratorio está terminada, podemos comprobar que la completamos en la página donde accedimos al laboratorio, nos debe aparecer **LAB Solved**.



Explicación del Payload

Payload utilizado:

/etc/passwd

Este laboratorio implementa un filtro que detecta y elimina las secuencias de traversal relativo (../) del parámetro filename antes de construir la ruta del archivo a cargar. Sin embargo, dicho filtro no valida si la cadena proporcionada es una ruta absoluta. Al enviar directamente /etc/passwd como valor del parámetro (sin usar ../ en ningún punto), el filtro no tiene nada que eliminar, ya que no reconoce ningún patrón de traversal relativo en la entrada. El servidor, al concatenar internamente el filename con el directorio base de imágenes, interpreta la barra inicial (/) como indicador de ruta absoluta y descarta el directorio base esperado, accediendo directamente a /etc/passwd en la raíz del sistema de archivos. De esta forma, se elude por completo el mecanismo de defensa, ya que este fue diseñado únicamente para detectar patrones de "retroceso" de directorios y no para restringir el uso de rutas absolutas.

Mitigación Recomendada

1. Validación mediante lista blanca (allow-list)

En lugar de aceptar cualquier nombre de archivo, validar la entrada contra una lista de archivos o patrones permitidos explícitamente. Esta es la mitigación más robusta, ya que no depende de detectar patrones maliciosos, sino de permitir únicamente lo que se sabe que es seguro.

2. Uso de indentificadores indirectos en lugar de nombres de archivo

Reemplazar el nombre de archivo real por un identificador (ID numérico o UUID) que se mapee internamente a la ruta del archivo en el servidor. De esta forma, el usuario nunca controla directamente ninguna porción de la ruta del sistema de archivos.